

INCIDENT RESPONSE REPORT

Phishing-Initiated RMM Backdoor Compromise

Host: QA-Pipeline-02

Prepared under NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide

Mapped to MITRE ATT&CK® Enterprise and SOC 2 Trust Services Criteria

Classification: Confidential — Restricted to Security, Compliance & Executive Leadership

Report ID	IR-2026-0304-001
Incident Date	04 March 2026
Report Date	01 May 2026
Prepared By	RismaFareedh — DFIR Analyst
Framework Basis	NIST SP 800-61 Rev. 2
Distribution	Restricted

Table of Contents

1. Document Control
2. Executive Summary
3. Incident Classification
4. Scope, Evidence Sources & Methodology
5. Timeline of Events (UTC)
6. Detection & Analysis
7. Indicators of Compromise (IOCs)
8. MITRE ATT&CK® Mapping
9. Root Cause Analysis
10. Impact Assessment
11. Containment, Eradication & Recovery
12. Post-Incident Activity & Lessons Learned
13. SOC 2 Trust Services Criteria Mapping
14. Recommendations Summary
15. Appendices

1. Document Control

Version	Date	Author	Description
1.0	01 May 2026	RismaFareedh — DFIR Analyst	Initial issue, based on post-incident forensic analysis (KAPE image review).

2. Executive Summary

On 04 March 2026, a Windows endpoint (QA-Pipeline-02) belonging to a startup organization was compromised through a phishing email that impersonated a personal event invitation. The email, sent from a free webmail account, directed the victim to a look-alike domain (pomi.digital) hosting a malicious executable disguised as an invitation viewer. Upon execution, the payload silently installed Datto RMM (agent name “CentraStage”) as a Windows service running under the LocalSystem account with automatic startup, granting the threat actor persistent, privileged remote administrative access to the endpoint.

The attacker further attempted to conceal the installation by timestamping the RMM binary's file-system metadata. The victim independently grew suspicious after the promised invitation did not materialize and ran a Microsoft Defender scan approximately three minutes after the backdoor was installed. This report reconstructs the full attack chain from a KAPE-collected forensic triage image, classifies the incident per NIST SP 800-61 Rev. 2, maps observed adversary behavior to MITRE ATT&CK®, and provides containment, eradication, recovery, and control-improvement recommendations mapped to SOC 2 Trust Services Criteria.

Status at time of report: forensic analysis complete; remediation actions in Section 11 should be executed and evidenced to close this incident.

3. Incident Classification

Field	Value
Incident ID	IR-2026-0304-001
Incident Category	Unauthorized Access — Persistent RMM-based Remote Administrative Access (analogous to US-CERT CAT 1)
Attack Vector	Email — Spearphishing Link (external free-mail lure)
Functional Impact	Low–Medium — Confirmed on a single endpoint (QA-Pipeline-02); no evidence within the provided image of lateral movement to other hosts.
Information Impact	Potential / Unconfirmed — Attacker obtained a fully privileged (LocalSystem) remote-access channel; whether data was accessed or exfiltrated cannot be confirmed from a single-host triage image.
Recoverability	Regular — single-host reimage and credential rotation expected to fully resolve
Overall Priority	High — Signed, legitimate RMM software abused for backdoor access is high-evasion and historically associated with follow-on ransomware / extortion activity.

4. Scope, Evidence Sources & Methodology

Evidence Source

A single-host forensic triage image was collected from QA-Pipeline-02 using KAPE (Kroll Artifact Parser and Extractor) and provided for offline analysis. No live-response, network capture, or EDR telemetry was available for this review.

Tools Used

Tool	Purpose
PhishTool	Email header / phishing indicator analysis
DB Browser for SQLite	Parsing Microsoft Edge browser history (downloads, navigation) artifacts
Eric Zimmerman's Registry Explorer	Parsing Amcache.hve for program-execution evidence
Eric Zimmerman's MFTECmd	Parsing the NTFS Master File Table (\$MFT) to CSV for timeline/timestamping analysis
Windows Event Viewer	Review of Windows Defender and Service Control Manager event logs
VirusTotal	File hash reputation, alternate filenames, digital-certificate status, and domain WHOIS/registration data

Limitations

- Single-endpoint scope — no visibility into other hosts on the network or evidence of lateral movement.
- No network packet capture — attacker command-and-control traffic and any data exfiltration cannot be directly confirmed.
- No EDR/antivirus quarantine telemetry beyond the single logged Defender scan event.
- Analysis is retrospective (post-mortem); no live containment actions were captured in the evidence set.

5. Timeline of Events (UTC)

Timestamp (UTC)	Event	Evidence Source
2026-02-20 01:06:05	Malicious domain pomi.digital registered by threat actor, 12 days prior to the phishing campaign.	VirusTotal WHOIS
2026-03-04 14:48:56	Phishing email "Special Party Invitation from JANET CARNAHAN" sent from businessinvitation432@gmail.com to CyberJunkieContractor@gmail.com, containing a malicious link.	PhishTool / .eml headers

Timestamp (UTC)	Event	Evidence Source
2026-03-04, prior to 16:44	Victim clicked the embedded link and downloaded premium.exe from https://pomi.digital/premium/windows_download.php into the Downloads folder.	Edge History (SQLite) / \$MFT row 226031
2026-03-04 16:44:33	First execution of premium.exe recorded on the host (Amcache InventoryApplicationFile entry).	Amcache.hve (Registry Explorer)
2026-03-04 16:44:45	CentraStage (Datto RMM) service silently installed — auto-start, LocalSystem account. Backdoor persistence established. (Event ID 7045)	Windows System Event Log
2026-03-04 16:48:00.98	Victim, having received no invitation, manually launched a Microsoft Defender Custom Scan against premium.exe. (Event ID 1000)	Microsoft-Windows-Windows Defender/Operational log
Discovered during forensic review	\$STANDARD_INFORMATION timestamps on CentraStage\Gui.exe found altered to 2026-02-09 07:56:40 UTC; true \$FILE_NAME kernel timestamps confirm actual creation at 2026-03-04 16:44:45 UTC — evidence of timestomping.	\$MFT — MFTECmd (\$SI vs \$FN comparison)

6. Detection & Analysis

6.1 Initial Access — Phishing Email

Header analysis in PhishTool confirmed the lure: subject “Special Party Invitation from JANET CARNAHAN,” sent from businessinvitation432@gmail.com (display name “Business invitation”) to CyberJunkieContractor@gmail.com at 2026-03-04T14:48:56Z, originating from IP 209.85.220.65 (mail-sor-f65.google.com). The body was deliberately brief, designed to drive a single click to an “exclusive invitation” link.

6.2 Delivery — Malicious Download

Microsoft Edge browser history (SQLite) showed the click resolved to https://pomi.digital/premium/windows_download.php, and the \$MFT (parsed via MFTECmd) confirmed the resulting file premium.exe landing in \Users\cyberjunkie\Downloads (record 226031).

6.3 Execution — Malicious Binary

Amcache.hve recorded the first execution of premium.exe at 2026-03-04 16:44:33 UTC (Root\InventoryApplicationFile\premium.exe). The associated FileId (SHA-1) was pivoted in VirusTotal to obtain the file's SHA-256 hash; VirusTotal further confirmed the binary's code-signing certificate has since been revoked by its issuer, and that it was also submitted under the alternate filename 5bxrx.exe.

6.4 Persistence & Privilege Escalation — RMM Backdoor Installation

Twelve seconds after execution, Windows System event 7045 (“new service was installed”) logged the silent creation of the CentraStage service (C:\Program Files (x86)\CentraStage\CagService.exe), configured for

automatic start under the LocalSystem account — providing the attacker SYSTEM-level, persistent remote access without needing a separate privilege-escalation exploit. CentraStage is the legacy agent name for Datto RMM, a legitimate product of Datto, Inc. commonly abused by threat actors because its signed binaries and normal-looking management traffic blend into legitimate business activity.

6.5 Defense Evasion — Timestomping

MFT analysis of CentraStage\Gui.exe revealed a divergence between the \$STANDARD_INFORMATION attributes (Created0x10 / LastModified0x10 = 2026-02-09 07:56:40 UTC, user-mode alterable) and the \$FILE_NAME attributes (Created0x30 / LastModified0x30 = 2026-03-04 16:44:45 UTC, kernel-written and not alterable via standard APIs). This divergence is definitive evidence the attacker attempted to backdate the RMM installation to evade timeline-based detection.

6.6 User-Initiated Detection

Having received no invitation, the victim grew suspicious and manually launched a Microsoft Defender Custom Scan against premium.exe at 2026-03-04T16:48:00.9828308Z (Event ID 1000), roughly three minutes after the backdoor had already been installed — underscoring that the compromise was identified through user vigilance rather than automated detection.

6.7 Threat Intelligence Context

VirusTotal WHOIS data showed pomi.digital was registered on 2026-02-20T01:06:05Z, only twelve days before the phishing email was sent — a pattern consistent with freshly registered, short-lived domains used for disposable phishing infrastructure.

7. Indicators of Compromise (IOCs)

Type	Indicator	Notes
Sender address	businessinvitation432@gmail.com	Display name “Business invitation”; free webmail, not a corporate domain
Email subject	“Special Party Invitation from JANET CARNAHAN”	Social-engineering lure
Malicious domain	pomi.digital	Registered 2026-02-20; 12 days before use
Malicious URL	https://pomi.digital/premium/windows_download.php	Payload delivery URL
Dropped file	premium.exe (alt. name: 5bxrx.exe)	Delivered to \Users\cyberjunkie\Downloads
SHA-1	405481d3d5529445c546d4425b72c5827ebde840	From Amcache FileId — leading 4 characters are Amcache padding, not part of the hash
SHA-256	af240a2c2a4b42e3a130f47ccaab8aa2e20a1a588bc959ee9efd7475055ea7e3	Resolved via VirusTotal; associated code-signing certificate has been revoked by its issuer
Persistence — service name	CentraStage	Datto RMM legacy agent name

Type	Indicator	Notes
Persistence — binaries	C:\Program Files (x86)\CentraStage\CagService.exe, \Gui.exe	Service runs as LocalSystem, auto-start
Affected host / user	QA-Pipeline-02 / cyberjunkie	QA endpoint, non-privileged interactive user

8. MITRE ATT&CK® Mapping

The following table maps observed adversary behavior to MITRE ATT&CK Enterprise tactics and techniques (ATT&CK v15).

Tactic	Technique ID	Technique	Observed Evidence
Resource Development	T1583.001	Acquire Infrastructure: Domains	pomi.digital registered by the threat actor 12 days before the phishing email was sent.
Initial Access	T1566.002	Phishing: Spearphishing Link	“Special Party Invitation” email containing a link to the attacker-controlled download page.
Execution	T1204.001	User Execution: Malicious Link	Victim clicked the link, triggering the download of premium.exe.
Execution	T1204.002	User Execution: Malicious File	Victim manually ran premium.exe; first execution logged in Amcache at 16:44:33 UTC.
Persistence	T1543.003	Create or Modify System Process: Windows Service	premium.exe silently installed the CentraStage service configured for auto-start (Event ID 7045).
Privilege Escalation	T1543.003	Create or Modify System Process: Windows Service	The same service was configured to run under the LocalSystem account, granting SYSTEM-level access without an exploit.
Defense Evasion	T1036	Masquerading	Payload distributed under benign-looking filenames (premium.exe / 5bxrx.exe) and delivered via a signed, legitimate RMM agent to blend with normal admin activity.
Defense Evasion	T1070.006	Indicator Removal: Timestamp	\$SI timestamps on CentraStage\Gui.exe backdated to 2026-02-09, contradicted by the kernel-level \$FN timestamp of 2026-03-04.
Command and Control	T1219	Remote Access Software	Datto RMM (CentraStage) provided the threat actor a persistent, full-featured remote monitoring and management channel over trusted infrastructure.

9. Root Cause Analysis

- No email filtering/URL sandboxing prevented a free-webmail phishing lure with an external download link from reaching the end user's inbox.

- No application allow-listing (e.g., AppLocker/WDAC) prevented execution of an unsigned, browser-downloaded executable from a user-writable directory.
- No approved-software / change-control process prevented silent installation of an unauthorized RMM agent.
- No real-time SIEM/EDR alerting existed for high-risk indicators (new-service creation running as LocalSystem, RMM installation outside change windows); the sequence was reconstructed only in retrospective forensic review.
- The compromise was ultimately surfaced by user vigilance rather than a technical control, indicating a detection gap rather than a purely human-error failure.

10. Impact Assessment

Property	Impact Level	Description
Confidentiality	Medium (potential)	LocalSystem-level RMM access gives the actor the technical capability to view, copy, or exfiltrate data; no exfiltration was confirmable from the single-host image.
Integrity	Medium	Timestamping of CentraStage binaries demonstrates deliberate anti-forensic tampering with file metadata.
Availability	Low	No destructive, ransomware, or denial-of-service activity was observed in the reviewed artifacts.

11. Containment, Eradication & Recovery

The reviewed evidence set is a post-incident forensic image; no containment actions were documented as having been executed. The following actions are recommended and should be evidenced as completed to close this incident.

11.1 Containment (Immediate)

- Isolate QA-Pipeline-02 from the network (EDR network quarantine or NIC disable) to sever the attacker's RMM channel.
- Block pomi.digital and any associated IPs/URLs at DNS, web proxy, and perimeter firewall.
- Stop and disable the CentraStage service without deleting it, preserving it as evidence pending eradication.
- Force a credential reset for the cyberjunkie account and any accounts with saved/cached credentials on the host.
- Confirm the existing KAPE forensic image and \$MFT/Amcache exports are preserved under chain of custody.

11.2 Eradication

- Remove the Datto RMM (CentraStage) agent, including CagService.exe and Gui.exe, after confirming the device has not been re-enrolled under a separate agent ID.

- Delete premium.exe / 5bxxr.exe and scan for any additional payloads dropped from the same session.
- Sweep the environment for the confirmed SHA-256 hash and the CentraStage service name on other endpoints to rule out lateral spread.
- Validate no additional persistence remains (scheduled tasks, Run/RunOnce keys, additional services).

11.3 Recovery

- Reimage QA-Pipeline-02 from a known-good baseline, given the SYSTEM-level nature of the compromise.
- Restore user data only after malware-free verification.
- Re-enroll the endpoint in EDR/monitoring before returning it to production.
- Monitor for 30 days for reinfection indicators (same hash, domain, or service name).

12. Post-Incident Activity & Lessons Learned

Per NIST SP 800-61 Rev. 2 Section 3.4, a lessons-learned review should be held with security, IT, and business stakeholders to close the incident lifecycle. Key discussion points and resulting corrective actions are below.

Gap Identified	Corrective Action	Owner	Priority / Target
No URL/attachment sandboxing on inbound email	Deploy secure email gateway with link rewriting and sandbox detonation	IT / Messaging	High — 30 days
No application allow-listing on endpoints	Implement AppLocker / WDAC to block execution from user-writable download paths	Endpoint Security	High — 60 days
No approved-software baseline enforcement	Publish and enforce an approved RMM/remote-access tool list; alert on deviations	IT Security	Medium — 45 days
No centralized log correlation for service installs	Forward Event IDs 7045, 4697 and Defender 1000-series to SIEM with real-time alerting	SOC	High — 60 days
Limited user awareness of external-lure phishing	Run phishing-simulation and awareness training focused on non-corporate senders	HR / Security Awareness	Medium — Quarterly
No formal runbook for user-reported suspicious files	Publish an IR triage/escalation playbook with defined SLAs	Security / IR Team	High — 30 days

13. SOC 2 Trust Services Criteria Mapping

The table below maps this incident's findings to the relevant SOC 2 (Security / Common Criteria) Trust Services Criteria, to support audit evidence and control-improvement tracking.

TSC	Focus Area	Observation	Recommendation
CC6.1	Logical access — restrict unauthorized software execution	No control prevented execution of an unsigned, browser-downloaded binary.	Deploy WDAC/AppLocker to block execution from Downloads/Temp; require code-signing verification.
CC6.6	Boundary protection against malicious code	Phishing email from an external free-mail account reached the inbox; the malicious domain was not blocked.	Enforce SPF/DKIM/DMARC, URL sandboxing, and reputation/age-based domain filtering.
CC6.8	Prevent/detect unauthorized or malicious software	A remote-access (RMM) tool was installed outside the approved software baseline.	Maintain an approved-software inventory and alert on installation of any unsanctioned RMM/remote-access agent.
CC7.1	Detect security events	Detection relied on retrospective log review rather than real-time alerting.	Forward relevant event IDs to a SIEM with correlation rules for new-service and RMM-install events.
CC7.2	Monitor for anomalies	Three correlated events (execution, service install, Defender scan) occurred within ~4 minutes with no alert raised.	Deploy EDR with behavioral detection for rapid “download-to-service-install” chains.
CC7.3	Evaluate identified security incidents	The incident was identified only after the user self-reported suspicion; no proactive detection triggered evaluation.	Establish a documented triage/escalation process with defined response SLAs.
CC7.4	Respond to identified security incidents	No documented containment/eradication actions were available for this host at the time of analysis.	Execute and document the containment/eradication actions in Section 11.
CC7.5	Recover from security incidents	Recovery and lessons-learned activity were pending as of this report.	Complete the recovery checklist in Section 11.3 and hold a post-incident review per Section 12.

14. Recommendations Summary

Short-Term (0–30 days)

- Complete containment/eradication/recovery actions in Section 11 and evidence their completion.
- Block confirmed IOCs (domain, hash, service name) across email, web, and endpoint controls.

- Reinforce a security-awareness reminder to staff regarding personal-themed lures from external senders.

Medium-Term (30–90 days)

- Roll out application allow-listing (AppLocker/WDAC) on endpoints, starting with high-risk user groups.
- Forward key Windows event IDs (7045, 4697, Defender 1000-series) to a SIEM with correlation/alerting rules.
- Publish and enforce an approved-software baseline covering RMM and remote-access tooling.

Long-Term (90+ days)

- Deploy EDR with behavioral detection for phishing-to-execution and rapid post-execution persistence chains.
- Formalize an incident-response runbook with defined SLAs and conduct periodic tabletop exercises.
- Run recurring phishing simulations and integrate threat-intelligence feeds for newly registered/low-reputation domains.

15. Appendices

Appendix A — Source Material

This IR report is prepared based on the KAPE-collected forensic artefacts provided by the “HTB Sherlock's Fruity” (timestamps, hashes, and log excerpts).

Appendix B — Distribution List

- Chief Information Security Officer
- IT / Security Operations Lead
- Compliance / Internal Audit
- Executive Sponsor (Affected Business Unit)